ENUMERAZIONE UTENTI MYSQL SU METASPLOITABLE

Studente: Vincenzo Lembo
Corso: Cybersecurity & Ethical Hacking
Esercitazione: W17D1 - Extra
Ambiente: Kali Linux, Metasploitable, UTM

---

1. Introduzione

L'esercitazione ha avuto come obiettivo l'identificazione degli utenti MySQL presenti sulla macchina vulnerabile Metasploitable, attraverso l'utilizzo di strumenti di scansione, verifica delle credenziali e interrogazione del database. L'attività è stata svolta in un ambiente di laboratorio controllato, utilizzando Kali Linux come macchina di analisi e Metasploitable come sistema target. La procedura ha permesso di individuare credenziali prive di password, effettuare un accesso remoto al servizio MySQL e ottenere l'elenco degli account configurati.

---

2. Obiettivo dell'esercitazione

La traccia richiedeva di ottenere la lista degli utenti MySQL presenti sul target Metasploitable.

Gli strumenti suggeriti erano:

- Nmap, con lo script NSE `mysql-brute`.
- Il client `mysql`, per accedere al database ed eseguire interrogazioni SQL.

L'obiettivo finale consisteva nell'identificare gli account presenti nel database MySQL.

2.1 Ambiente di laboratorio

L'esercitazione è stata svolta utilizzando due macchine virtuali configurate sulla stessa rete.

Macchina	Indirizzo IP	Ruolo
Kali Linux	192.168.50.100	Macchina di analisi
Metasploitable	192.168.50.101	Sistema target

---

4. Ricognizione e identificazione del servizio MySQL

La prima operazione è consistita nell'identificazione dei servizi attivi sulla macchina Metasploitable.

Dal terminale di Kali Linux è stato eseguito:

```
nmap -sV 192.168.50.101
```

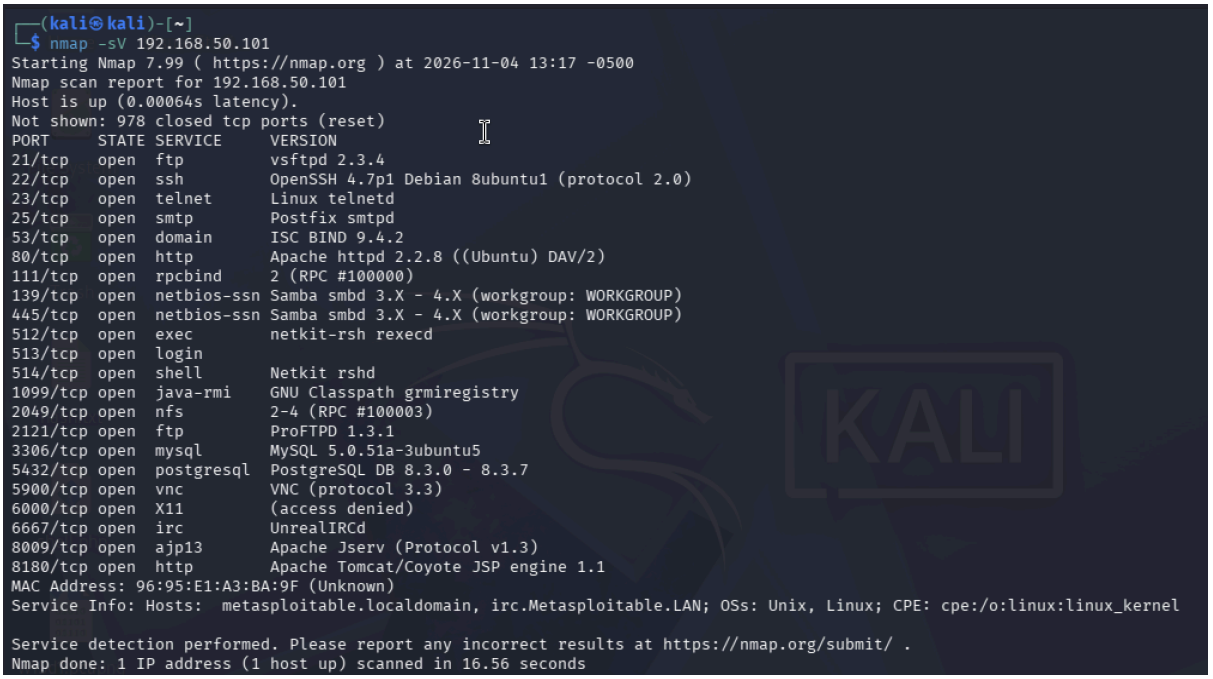
Il parametro `-sV` consente di identificare i servizi attivi e determinarne, quando possibile, le relative versioni.

La scansione ha individuato diversi servizi esposti, tra cui MySQL.

Il servizio di interesse è risultato:

```
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5
```

Il risultato ha confermato che il server MySQL era attivo e raggiungibile attraverso la porta TCP 3306.



---

5. Verifica delle credenziali con mysql-brute

Dopo aver identificato il servizio MySQL, è stato utilizzato lo script `mysql-brute`, come suggerito dalla traccia.

Il comando eseguito è stato:

```
nmap --script mysql-brute 192.168.50.101
```

Lo script effettua tentativi di autenticazione utilizzando combinazioni di nomi utente e password, con l'obiettivo di individuare credenziali valide.

L'esecuzione ha restituito:

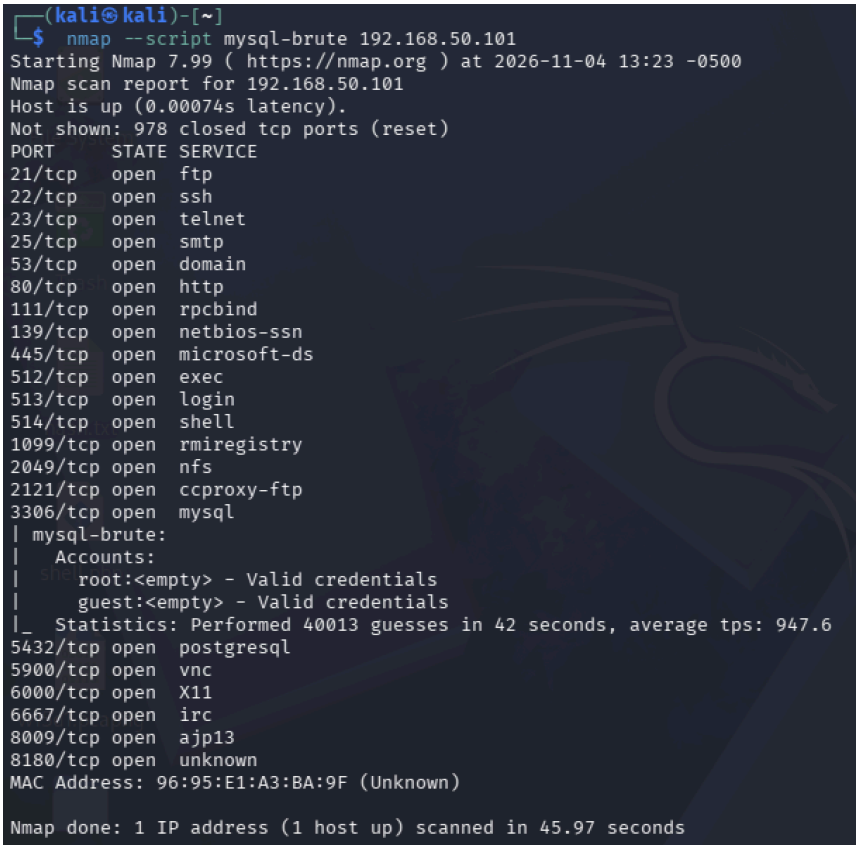
```
mysql-brute:
  Accounts:
    root:<empty> - Valid credentials
    guest:<empty> - Valid credentials
```

Sono stati identificati due account con credenziali valide:

Utente	Password	Esito
root	Vuota	Autenticazione valida
guest	Vuota	Autenticazione valida

Il risultato ha evidenziato una configurazione insicura del servizio, poiché entrambi gli account accettavano autenticazioni senza password.

Particolarmente significativa è risultata la presenza dell'account amministrativo `root` privo di password.



6. Accesso remoto al database MySQL

Dopo aver individuato le credenziali valide, è stato effettuato un tentativo di connessione al server utilizzando l'account `root`.

Dal terminale di Kali Linux è stato eseguito:

```
mysql -u root -h 192.168.50.101 --skip-ssl
```

I parametri utilizzati sono:

- `-u root`: specifica l'account utilizzato per l'autenticazione.
- `-h 192.168.50.101`: indica l'indirizzo IP del server MySQL.
- `--skip-ssl`: disabilita l'utilizzo di SSL per la connessione.

Non è stato necessario specificare una password, poiché l'account `root` ne era privo. La connessione è avvenuta correttamente.

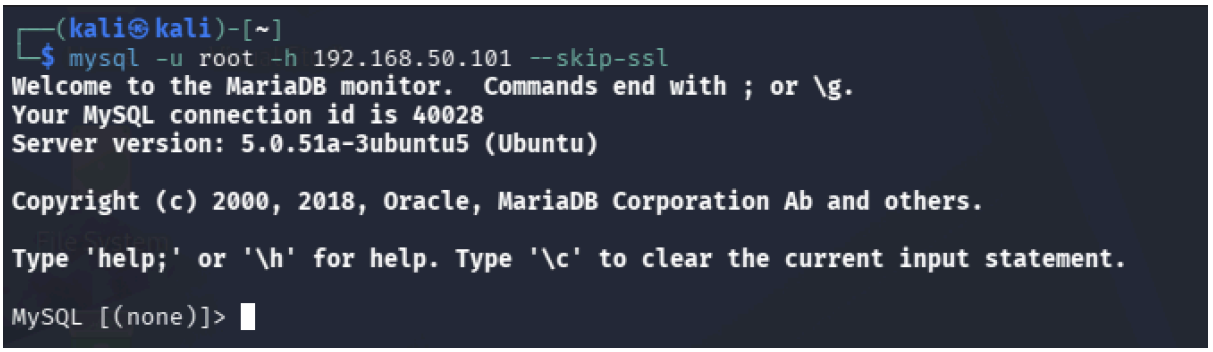
Il server ha restituito le informazioni relative alla versione installata:

```
Server version: 5.0.51a-3ubuntu5 (Ubuntu)
```

È stato inoltre visualizzato il prompt interattivo:

```
MySQL [(none)]>
```

Questo risultato ha confermato la possibilità di accedere da remoto al database MySQL utilizzando l'account amministrativo senza password.



7. Enumerazione degli utenti MySQL

Una volta ottenuto l'accesso al server, è stata eseguita una query SQL per identificare gli utenti presenti nel database.

Il comando utilizzato è stato:

```
SELECT User, Host, Password FROM mysql.user;
```

La query permette di recuperare i nomi degli account MySQL e i relativi valori del campo `Host`, che contribuiscono a definire da quali host possono autenticarsi e ha permesso di visualizzare anche il campo `Password` associato agli account.

L'interrogazione ha restituito tre account:

User	Host	Password
debian-sys-maint	Vuoto	Vuota
root	%	Vuota
guest	%	Vuota

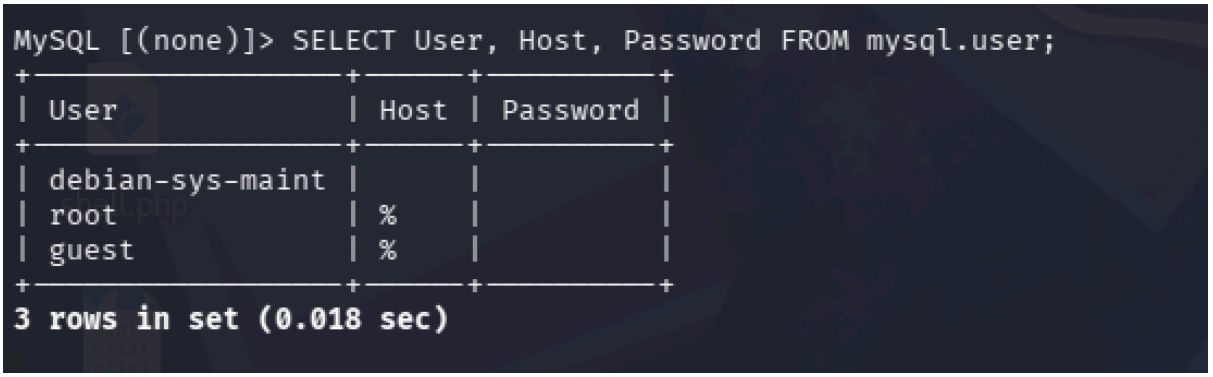
Il simbolo `%` rappresenta un carattere jolly che consente la corrispondenza con qualsiasi host, compatibilmente con le altre condizioni di accesso.

Il risultato ha permesso di identificare tutti e tre gli account presenti nella tabella interrogata.

Il risultato ha mostrato valori vuoti nel campo `Password` per tutti e tre gli account.

La possibilità di autenticarsi senza password per `root` e `guest` era già stata confermata dallo script `mysql-brute`.

Per l'account `debian-sys-maint`, invece, è stato osservato il campo password vuoto, senza effettuare un test diretto di autenticazione.



---

8. Conclusioni

L'esercitazione è stata completata con successo, raggiungendo l'obiettivo richiesto dalla traccia.

Attraverso Nmap è stato identificato il servizio MySQL attivo sulla macchina Metasploitable, mentre lo script `mysql-brute` ha consentito di individuare due account con password vuota.

Successivamente, utilizzando il client MySQL, è stato possibile effettuare un accesso remoto con l'account amministrativo `root` ed eseguire interrogazioni sulla tabella `mysql.user`.

L'analisi ha permesso di identificare tre account: `root`, `guest` e `debian-sys-maint`.

L'esercizio ha dimostrato come una configurazione di autenticazione non sicura possa consentire l'accesso non autorizzato a un servizio database e l'enumerazione degli account presenti.

Vincenzo Lembo